Übungsaufgaben -

DHBW
Duale Hochschule
Baden-Württemberg
Mannheim

Passwortwiederherstellung

Dozent: Prof. Dr. Michael Eichberg
Kontakt: michael.eichberg@dhbw-mannheim.de , Raum 149B
Version: 24SEA

Einführung

Diese Aufgaben sollen Sie auf das bewertet Lab vorbereiten. Diese Aufgaben sind dazu da, dass Sie die Wiederherstellung von Passwörtern üben können.

Die im Rahmen des Labs bewerteten Aufgaben werden strukturell sehr vergleichbar sein.

Der Einsatz von Kali Linux ist empfehlenswert, da dort sehr viele Tools (insbesondere Hashcat und John) schon installiert sind oder vgl. trivial nachinstalliert werden können. Unter Kali finden Sie interessante (Basis-)Wörterbücher an folgenden Stellen:

```
/usr/share/dict/wordlist-probable.txt
/usr/share/dict/cracklib-small
/usr/share/wordlist/rockyou.txt
/usr/share/wordlists/metasploit/*.txt
```

▲ Achtung!

Auch in Kali Rolling sind nicht immer alle Tools auf dem allerneuesten Stand bzw. direkt verfügbar.

Es ist weiterhin möglich, dass die Verwendung von Hashcat und/oder John nicht (direkt) möglich ist und erst Vorverarbeitungsschritte durchgeführt werden müssen!

⊘ !GEFAHR!

Vor der Installation von *Hashcat* und *John the Ripper* auf dienstlichen Notebooks sollten/müssen Sie unter allen Umständen klären ob Ihre Unternehmensrichtlinien dies erlauben!

Es kam in der Vergangenheit praktisch jedes Semester dazu, dass Studierenden die dienstlichen Notebooks unmittelbar nach der Installation von Cybersicherheitstools direkt gesperrt und teilweise sogar unmittelbar vollständig gelöscht wurden!

Dies gilt ganz insbesondere für Studierende der SAP.

◆ Bemerkung

Im Rahmen der Passwortwiederherstellung kann es immer mal wieder vorkommen, dass Ihnen eine Aufgabe mehr oder weniger liegt. Sie sollten sich deswegen alle Aufgaben anschauen!

Zu entwickelnde Fähigkeiten

Lösungswegbeschreibungen

Für jede Aufgabe müssen Sie in der Lage sein Ihren Weg genau zu beschreiben, da dies essentieller Bestandteil der Prüfung ist.

Vorbereitungsschritte

01	[ggf.] Schritte zur Extraktion des Hashes
02	[ggf.] Schritte, die zur Aufbereitung des Hashes unternommen wurden
03	[ggf.] verwendete Quellen für (externe) Wörterbücher
04	[ggf.] Schritte, die zur Erstellung des zum Angriff benutzten Wörterbuchs unternommen wurden
05	[ggf.] Schritte, die notwendig waren, um das notwendige Tooling bereitzustellen

Eigentlicher Angriff

06	den oder die Schritte, die zum Angriff auf den oder die „Hashes“ durchgeführt wurden
07	das oder die wiederhergestellten Passworte
08	Dauer der Suche nach dem Passwort (Dies ist die Zeit, die gebraucht wurde, um ihre Passwortkandidaten zu testen; d.h. die Zeit, die zum Beispiel Hashcat benötigt hat. Eine grobe Angabe in Minuten ist ausreichend.)

!! Wichtig

Sie müssen in der Lage sein nachvollziehbar zu beschreiben wie Sie das Passwort ermittelt haben.

◆ Bemerkung

Auch, wenn bei den folgenden Aufgaben immer das Endziel ist die Passwörter wieder herzustellen, so ist für die Bewertung der Weg der ausschlaggebende Aspekt. Sollten Sie einen sinnvollen und gut begründbaren Weg eingeschlagen haben, waren jedoch nicht erfolgreich, dann kann das Ziel im Hinblick auf das Lab erreicht sein.

✎ Numbers<X> Datei

Bzgl. des Passwortes und des Hintergrundes sind keine Informationen vorhanden. Es bleibt Ihnen nichts anderes übrig als allg. *Best Practices* anzuwenden. Sollten Sie das Passwort der `Number<X>` nicht wieder herstellen können, dann können Sie sich auch an der Datei `Poem.pages` versuchen.

!! Wichtig

Bearbeiten Sie „nur“ irgendeine `Number<X>` Datei; die Komplexität ist bei allen gleich.

✎ Hurdle.jpg.7z

Ihnen liegt eine verschlüsselte, komprimierte Datei zur Entschlüsselung vor. Glücklicherweise(?) konnten sie auf einem Datenträger eine gelöschte Datei wieder herstellen, die `Passworte.txt` hieß und die folgenden Daten beinhaltet.

```
Der Lauf
Der Flug
Der Gesang
Der Fund
Der Stand
```

✎ Star.pdf

Ihnen liegt ein verschlüsseltes PDF vor. Aus anderen Fällen in dem Umkreis der Beschuldigten wissen Sie, dass diese eine starke Tendenz haben Passworte zu bauen, die aus großen deutschen Städten zusammengesetzt sind und ergänzt werden um Zeichen, die notwendig sind, um ggf. die Passwort-policies Ihrer Standardapps zu erfüllen. In diesem Fall ist die Passwortpolicy der verwendeten App bekannt:

- mind. 2 Großbuchstaben
- mind. 2 Kleinbuchstaben
- mind. 4 Ziffern
- mind. 4 Sonderzeichen
- mindestlänge: 16 Zeichen

Sie wissen auch, dass die verwendeten Sonderzeichen praktisch immer: $, € oder ! sind und in den Passworten häufig einfach wiederholt werden. Weiterhin werden fast immer aktuelle Jahreszahlen verwendet (z. B. 2023 etc.) und der allgemeine Aufbau scheint:

`<Jahreszahl><Stadt1><Stadt2><Sonderzeichen>`
zu sein.

MySheet

Basierend auf anderen Passworten, die sie in einem Notizbuch gefunden haben, gehen Sie davon aus, dass für das Passwort nur reguläre Buchstaben verwendet wurden und Worte mit der korrekten Groß-Kleinschreibung geschrieben werden (z. B. Frankfurt). Wörter scheint er ggf. zusammenzuziehen (z. B. HausMaus, AffeAffe, alleLieben). Darüber hinaus konnten Sie nur noch die Erkenntnisse gewinnen, dass alle Passworte mindestens 8 Buchstaben haben.

✎ Java Hashcodes

In einer Software wurde fälschlicherweise Javas `hashcode()` Funktion für das Hashen der Passworte verwendet. Aus der Datenbank konnte eine Liste von Hashes extrahiert werden. Diese Werte sind in der Datei `JavaHashcodes` gespeichert.

Ihre Aufgabe ist die Wiederherstellung *aller* Passworte.

✎ Max Mueller

Ihre Aufgabe ist das Passwort für die Datei `Max Mueller.kdbx` wiederherzustellen.

Sie haben zur Unterstützung Ihrer Tätigkeit eine Profilbeschreibung erhalten: `Max Mueller.md`.

Passwords.pages

Ihnen liegt die vielversprechend klingende Datei `Password.pages` vor.

Ihre Aufgabe ist die Wiederherstellung des Passwortes.

✎ Personal Information

Sie erhalten eine Datei (`persona1_information.aes256cbc_sha1.encrypted`), die verschlüsselt erscheint und auch eine Liste mit möglichen Passwortkandidaten:

`persona1_information.aes256cbc_sha1.password_candidates.txt`

Finden Sie heraus, ob das Passwort dabei ist und entschlüsseln Sie ggf. die Datei. Ermitteln Sie als Erstes, welche Software wahrscheinlich verwendet wurde, um die Datei zu erzeugen.